

Application Security & HIPAA Breach-Penalty Exposure

Early Access · MessageFoundry v0.3.2 · July 2026

A CISO-facing primer on how the depth of application-security verification shapes HIPAA breach-penalty exposure — and how MessageFoundry's OWASP ASVS Level 3 self-assessment fits into a buyer's diligence.

Not legal advice. This page is educational and informational only. Nothing here is legal or compliance advice, no attorney-client relationship is created by reading it, and it is not a substitute for your own counsel's judgment about your organization's obligations.

Source and date of the dollar amounts below. The penalty figures on this page are taken from the table at [45 CFR 102.3](#) as most recently revised by HHS in *Annual Civil Monetary Penalties Inflation Adjustment*, final rule, [91 FR 3665](#) (Jan. 28, 2026; FR Doc. 2026-01688) — the "2025 Maximum adjusted penalty" column, effective on publication and applicable to penalties assessed on or after January 28, 2026 for violations occurring on or after November 2, 2015.

HHS re-adjusts these amounts for inflation most years, so **check for a newer notice before relying on them**; they are also subject to enforcement discretion by the HHS Office for Civil Rights (OCR), and the tier a matter lands in is a legal judgment, not a lookup. Confirm every amount — and every compliance question — against the current HHS table and with your own counsel and compliance team.

Why application-security depth is a financial question, not just an engineering one

When software that creates, receives, maintains, or transmits protected health information (PHI) is involved in a breach, the depth of security verification applied to that software is one of the largest factors driving the *financial* exposure that follows — not only the engineering quality.

The reason is structural. U.S. HIPAA civil monetary penalties are assigned by **tier**, and the tier turns on **culpability** — whether the organization exercised reasonable diligence or was, in effect, neglectful — rather than on the severity of the breach itself. Documented, tested application-security verification is exactly the kind of evidence that supports a lower-culpability finding. The absence of it removes that evidence.

A structured verification standard such as **OWASP ASVS Level 2–3** produces that evidence as a byproduct of normal engineering. The same artifacts that make software more secure also make it more *defensible*.

How OCR assigns a penalty tier

OCR places each HIPAA violation into one of four tiers based on culpability. The tier structure is set by statute; the dollar amounts are inflation-adjusted by HHS. The per-violation amounts below are the current ones, from the table at 45 CFR 102.3 as revised by 91 FR 3665 (Jan. 28, 2026):

Tier	Culpability	Per-violation range	Annual cap (per provision)
1	No knowledge (reasonable diligence)	\$145 – \$73,011	\$25,000 (discretionary)
2	Reasonable cause	\$1,461 – \$73,011	\$100,000 (discretionary)
3	Willful neglect — corrected	\$14,602 – \$73,011	\$250,000 (discretionary)
4	Willful neglect — not corrected	\$73,011 – \$2,190,294	\$2,190,294 (statutory)

Note that the **per-violation maximum is the same \$73,011 in all four tiers** — the tiers differ in their *minimums*, not their maximums (45 CFR 160.404(b)(2)(i)–(iv)(B)). It is the annual cap, not the per-violation ceiling, that separates a Tier 1 outcome from a Tier 4 one.

The "(discretionary)" caps in tiers 1–3 are not the statutory annual limit. They come from OCR's 2019 [Notification of Enforcement Discretion Regarding HIPAA Civil Money Penalties](#), in which OCR said it would apply lower annual limits to the first three tiers. The regulation's own table still carries the higher statutory annual amount across all four tiers — so which figure applies to a given matter is a question for counsel, not a number to read off a vendor page.

For internally developed or deployed software that touches PHI, the tier hinges on a straightforward narrative: were PHI safeguards **documented and tested** (reasonable diligence → Tier 1–2), or was software shipped without adequate controls despite the known risk (willful neglect → Tier 3–4)? An established, documented security program — together with prompt detection, containment and correction — is the kind of record that supports placement in the lower tiers.

Why the annual caps are the real headline

The per-violation dollar amounts draw attention, but the larger exposure lives in the **annual caps**, which are tiered by culpability:

Penalty tier	Annual cap per identical violated provision
Tier 1 — no knowledge	\$25,000
Tier 2 — reasonable cause	\$100,000
Tier 3 — willful neglect, corrected	\$250,000
Tier 4 — willful neglect, not corrected	\$2,190,294

(The Tier 4 figure is the statutory cap from 45 CFR 102.3 as revised by 91 FR 3665, Jan. 28, 2026. The Tier 1–3 figures are the lower annual limits from OCR's 2019 enforcement-discretion notice, not inflation-adjusted amounts from that table — see the note below. Check the current HHS schedule before relying on any of them.)

A single breach commonly implicates **several distinct provisions** at once, so the caps apply in parallel and stack. That is why the difference between a Tier 1–2 outcome and a Tier 3–4 outcome compounds quickly: it is the gap between discretionary caps in the tens of thousands per provision and a statutory cap in the millions. Where a given breach lands within these ranges is driven by three things — the tier OCR assigns, whether the organization can demonstrate recognized security practices for the prior 12 months, and the number of individuals affected.

Where ASVS changes the outcome

OWASP ASVS (Application Security Verification Standard) is a structured catalog of application-security requirements organized into three verification levels:

- **Level 1** — surface-level checks.
- **Level 2** — the working standard for applications handling sensitive data such as PHI.
- **Level 3** — the most rigorous level, intended for the highest-risk systems.

The ASVS chapters covering **cryptography, access control, error handling, logging, and the protection and retention of regulated data** map onto the technical safeguards the HIPAA Security Rule requires. The practical effect is that a completed ASVS Level 2–3 verification produces the documentation OCR looks for when distinguishing diligence from neglect: encryption verified, access controls tested, audit logging confirmed, input validation in place — each is simultaneously an ASVS requirement and a Security Rule control.

Conversely, software shipped with only surface checks — or with none documented — offers OCR no evidence of diligence and invites a willful-neglect finding.

The HITECH "recognized security practices" lever

A 2021 amendment to the HITECH Act requires OCR to **consider whether an organization had recognized security practices in place for the prior 12 months** when determining penalties and the scope of an audit. The recognized categories include the **NIST Cybersecurity Framework**, the **HICP / Section 405(d)** practices, and other statutorily recognized programs.

Because an ASVS Level 2–3 verification produces the same class of evidence those frameworks ask for, its artifacts can become part of the package that supports this mitigation. Two caveats matter:

- **It is not a safe harbor.** Implementing recognized practices does not grant immunity from liability. It *mitigates* penalties and can shorten or terminate an audit.
- **Documentation and duration are everything.** The mitigation contemplates demonstrable implementation sustained over time — which is why the artifacts are most useful when generated as part of the normal development lifecycle, not assembled after an incident.

Notably, the *absence* of recognized practices is not treated as an aggravating factor that increases penalties — but it leaves an organization with no mitigation lever to pull.

How MessageFoundry's ASVS L3 self-assessment supports your diligence

MessageFoundry is developed against the **OWASP ASVS 5.0 Level 3** catalog — a level above the Level 2 bar typically expected of PHI-handling applications — and a documented self-assessment against that catalog's 345 requirements is maintained as part of the engineering record. Every control in it is either built or carries a **documented residual**.

What this is — and is not:

- It is a **point-in-time, AI-assisted self-assessment**. It is **not a certification, not an audit, and not an independent review**, and we do not describe it as one. Neither OWASP nor NIST issues a certificate, and a self-assessment is not one.
- **We publish no pass/fail count**. The scoring is under reconciliation, and by the project's own rule no figure is quotable until the final re-score lands — so a count here would be a claim we could not stand behind. (An earlier count circulated on this site and elsewhere; the document it came from has since been marked superseded as unreliable, and the figure was withdrawn.)
- **There has been no third-party assessment, no penetration test and no dynamic (DAST) testing to date**. That gap is carried as a signed, dated standing risk acceptance in the engineering record. An independent engagement is planned — it is a \$25,000–\$50,000 commitment the project intends to fund by grant or sponsorship — but it is **not something already behind us**. Because MessageFoundry is self-hosted, whether that gap is acceptable for a given deployment is a judgement for the **implementing organization**, and it is stated here plainly so your team can make it.
- The assessment set itself is maintained privately and can be made available to evaluators and security reviewers under NDA. The rule that decides what is published and what is withheld — and how to request the rest — is written down in the project's [security-documentation policy](#).
- We say MessageFoundry **supports a HIPAA-compliant deployment**. We do not say "HIPAA compliant," "NIST certified," "ASVS certified," or "guaranteed" — compliance is a property of *your* deployment and program, not of any single component.

The point for a buyer's diligence is practical: the controls this work covers — encryption at rest and in transit, deny-by-default role-based access control, a hash-chained user-attributed audit trail, ingress validation, and disciplined handling of regulated data — are the same controls that map onto the HIPAA Security Rule's technical safeguards and onto the recognized-practices frameworks above. The self-assessment, and the artifacts behind it, are designed to slot into the evidence package your compliance team maintains — with its limits stated plainly enough that your team can weigh them.

Interface authentication reflects the same posture:

- **Inbound**, partner interfaces are protected by TLS, with **mutual TLS available per connection** — an MLLP listener can require and verify a partner client certificate, and the engine API can require a client certificate and resolve its verified subject to a named principal. The engine **refuses to serve a non-loopback plaintext bind** rather than quietly putting bearer tokens and PHI on the wire.
- **Outbound**, MessageFoundry authenticates itself to partner systems with **OAuth 2.0 client-credentials** and **SMART-on-FHIR Backend Services** (signed-JWT client assertion) for FHIR/REST destinations, and **WS-Security** for SOAP.

- **Operators** sign in against local accounts or Active Directory. A **second factor is required for local accounts by default** — native TOTP or a browser WebAuthn passkey — while AD-backed accounts have their MFA delegated to the directory or identity provider.
- The browser **web console** surfaces operational integrity through **Alerts** and **Dead-Letters**, and the engine exposes a permission-gated Prometheus-style `/metrics` endpoint for your monitoring stack.

Deployment guidance

Strong application-security verification establishes the floor; a sound deployment preserves it. A few standing guidelines:

- **Terminate TLS for any listener exposed beyond loopback.** Running a listener on `localhost` for local testing is fine in the clear; the moment a listener is reachable off the host, it should sit behind TLS (and, where appropriate, mTLS). MessageFoundry enforces this rather than trusting it — an off-loopback plaintext bind is refused at startup.
- **Put enterprise operators in your directory**, so MFA and account lifecycle are governed by your existing identity provider; local accounts keep the engine's own second-factor requirement.
- **Retain verification and operational artifacts** — assessment results, audit logs, alert and dead-letter history — as ongoing evidence, generated through the normal lifecycle rather than reconstructed after the fact.

These are deployment responsibilities shared by any PHI-handling system, not gaps in the product.

Takeaway

For any software that creates, receives, maintains, or transmits PHI, documented application-security verification at **OWASP ASVS Level 2–3** is worth treating as a standard, retained deliverable. It shifts realistic breach-penalty exposure from the willful-neglect tiers toward the reasonable-diligence tiers, and it contributes to the HITECH recognized-security-practices record that mitigates penalties across an entire environment — not just one application. MessageFoundry's ASVS 5.0 Level 3 self-assessment — with its scope, its residuals and its missing independent review all stated — is built to make that record easier for your team to assemble and easier for your team to audit.

Further reading

- OWASP Application Security Verification Standard (ASVS): <https://owasp.org/www-project-application-security-verification-standard/>
- HHS OCR — HIPAA enforcement and penalties: <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/index.html>
- HHS civil monetary penalty amounts, 45 CFR Part 102: <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-A/part-102>
- NIST Cybersecurity Framework: <https://www.nist.gov/cyberframework>
- HHS 405(d) — Health Industry Cybersecurity Practices (HICP): <https://405d.hhs.gov/>

- MessageFoundry security overview:
<https://github.com/MEFORORG/MessageFoundry/blob/main/docs/SECURITY.md>
- MessageFoundry security-documentation policy (what is public, what is not, how to ask):
<https://github.com/MEFORORG/MessageFoundry/blob/main/docs/SECURITY-DOCS-POLICY.md>

MessageFoundry is an independent project and is not affiliated with, endorsed by, or sponsored by any of the standards bodies or agencies referenced above. Product and company names mentioned elsewhere on this site are trademarks of their respective owners.

© 2026 **MEFOR-ORG**, a non-profit · MessageFoundry is licensed under **AGPL-3.0-or-later** · Document generated July 2026 for MessageFoundry v0.3.2.

MessageFoundry and the MessageFoundry word mark are trademarks of MEFOR-ORG. This document describes an **Early Access** release; check pypi.org/project/messagefoundry for the current version. Verify specifics against your own deployment and the engine's reference documentation.